It may seem like overkill for the server to weigh in on response headers. After all, what harm can the X-Powered-By header do? But like the other CORS headers, the Access-Control-Expose-Headers header exists to protect the server's data from unexpected access. Accessing response headers is a new capability introduced by CORS. Before CORS existed, clients had no way of reading the response headers. Because a server may depend on this behavior, CORS needs to be careful not to break this assumption. The Access-Control-Expose-Headers header ensures that the client code can only read the response headers intended by the server.

5.3 Summary

This chapter rounded out your understanding of CORS by introducing a few additional features:

- The Access-Control-Allow-Credentials header can be used in conjunction with `XMLHttpRequest`'s `withCredentials` property to include cookies on cross-origin requests.
- The Access-Control-Expose-Headers header can be used to expose response headers to the client.

These features are the tools in your CORS toolbox. But the tools alone aren't enough; you also need to know how to use them. The flexibility offered in CORS means that there are a lot of ways of configuring a server, and there sometimes isn't any clear guidance on which way is preferred. The next chapter offers guidance and best practices for using CORS on your own server.